SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I G. PRANATHI [192472237] certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: G. PRANATHI

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

1 Purpose and scope of the Nmap report

The scenario states that a security analyst scanned the authorised target 192.168.1.10 with Nmap and observed HTTP on TCP port 80, SSH on TCP port 22, and MySQL on TCP port 3306. The scan also identified an operating system and service versions. This information is useful for asset discovery and vulnerability assessment because it describes which network services appear reachable and may help defenders prioritise further checks.

An Nmap result must be interpreted carefully. An open port means that a service accepted a connection or responded in a way consistent with listening on that port at the time of the scan. It does not automatically mean that the service is vulnerable, exposed to the public internet, or already compromised. Risk depends on the software version, configuration, authentication, network location, business purpose, and available security updates.

The first task is to validate the asset owner, scan scope, date, source address, scan options, and whether the host is a production system. The analyst should compare the result with the approved asset inventory and change records. If the host is expected to provide only a web application, an exposed database listener may be an unnecessary service and should be investigated.

Because the address is in the private 192.168.0.0/16 range, it is normally used inside private networks and is not directly globally routable. However, internal exposure still matters: compromised employee devices, malicious insiders, or a foothold on another server may allow an attacker to reach it.

Record the scan time and authorised scope.

Confirm whether each service is required for the host's role.

Treat version detection as an indicator to verify, not conclusive proof of a vulnerability.

Interpreting ports and service versions :

TCP port numbers provide useful clues about likely services. Port 80 commonly serves unencrypted HTTP; port 22 commonly provides SSH remote administration; and port 3306 commonly provides MySQL database access. Administrators can configure services to use different ports, so service identification should be confirmed through banners, application configuration, logs, and approved validation methods.

Service-version detection can support patch assessment. A reported product and version can be compared with vendor security advisories and vulnerability databases. The comparison

must include distribution-specific backports and vendor patches: a package may retain an older-looking version string while containing a security fix. Conversely, a current-looking version can still be insecure because of weak settings or vulnerable plugins.

An analyst should separate evidence from inference. Evidence includes the port state, detected service, version string, and scan conditions. Inferences include the possibility of outdated software, weak authentication, excessive exposure, or known vulnerabilities. These inferences require confirmation before they are recorded as confirmed findings.

A good report assigns each finding a severity, likelihood, business impact, confidence level, and remediation owner. Severity should reflect exploitability and consequences rather than simply the port number. For example, a database service reachable from an untrusted network may deserve urgent attention, while a properly restricted service required by an application may have lower exposure.

Finding	**What it indicates**	**What must be verified**
TCP/80 HTTP	A web service may be listening	Application, TLS configuration on related endpoints, headers, patch status, authentication
TCP/22 SSH	Remote administration may be available	Allowed source networks, authentication methods, account policy, patch level
TCP/3306 MySQL	A database listener may be reachable	Network ACLs, bind address, accounts, TLS, privileges, data sensitivity
OS/version data	May support asset and patch identification	Fingerprint confidence, vendor advisories, installed package details

HTTP service: security risks :

HTTP on port 80 normally transmits application traffic without transport encryption. If credentials, session cookies, personal information, or business data travel over plain HTTP, a person able to observe or manipulate traffic on the path may be able to read or alter it. This

risk is especially relevant on shared wireless networks, compromised internal segments, or networks where an attacker can perform traffic interception.

The web application itself may contain vulnerabilities such as injection, cross-site scripting, broken access control, insecure file uploads, exposed administrative pages, outdated components, or weak session management. Nmap detecting HTTP does not demonstrate any of these weaknesses; they require an authorised web application assessment. A server may also disclose unnecessary details through response headers, directory listings, default pages, or verbose error messages.

Attackers commonly begin by mapping reachable web paths and identifying the software stack. If a known vulnerability affects the actual installed version and configuration, it may provide a route to data exposure, account compromise, or in severe cases remote code execution. Weak credentials or misconfigured administrative functions can also be targeted. These are possible attack paths, not conclusions from the port number alone.

Defenders should redirect HTTP requests to HTTPS where appropriate, use valid TLS certificates and modern TLS settings, and mark session cookies Secure and HttpOnly. Remove default content, disable directory listing, patch the server and application, enforce strong access control, validate inputs, and log security-relevant events. A web application firewall may add defence in depth, but it does not replace secure application code.

Confirm whether port 80 is needed and whether it redirects to HTTPS.

Review the application against the OWASP Top 10 and secure configuration guidance.

Keep web server, framework, libraries and plugins patched.

Limit administrative interfaces and monitor for unusual requests.

SSH service: security risks :

SSH provides encrypted remote administration and is generally safer than clear-text remote login protocols. Nevertheless, an SSH listener can create risk if it is exposed to too many networks, uses weak account credentials, permits inappropriate privileged logins, or runs vulnerable software. Attackers may attempt password guessing, credential stuffing using reused passwords, or exploitation of a confirmed software flaw.

The existence of port 22 does not prove that password authentication is enabled or that the service is weak. The administrator must check the effective SSH configuration, permitted users and groups, authentication methods, cryptographic settings, patch history, and source-network

restrictions. A service can be correctly configured and still require monitoring because administrative access is a high-value target.

If an attacker obtains valid credentials, the impact depends on the account's privileges and the host's role. Possible consequences include unauthorised command execution, access to files, installation of persistence, or movement to other systems. If privileged accounts are permitted to log in directly, a stolen credential may have a much larger impact. These risks can be reduced through layered controls.

Recommended controls include using SSH keys or an approved certificate-based method, protecting private keys with passphrases and secure storage, disabling password authentication where operationally feasible, and preventing direct root login. Restrict access through a VPN, bastion host, or firewall allowlist. Enforce multi-factor authentication where supported, remove unused accounts, rotate compromised credentials, and monitor successful and failed logins.

Permit only required administrators and source networks.

Use supported SSH versions and strong, approved cryptographic settings.

Apply rate limiting or equivalent protective controls without blocking legitimate administration.

Review logs and alert on repeated failures, new keys, and unusual login times.

MySQL service: security risks :

MySQL on TCP port 3306 is a database listener. Databases often contain customer records, employee information, credentials, transactions, or application data, so unnecessary network access can have significant consequences. A database should generally be reachable only by application servers and authorised database administrators, not by every device on the network.

Risks include weak or reused database passwords, excessive account privileges, anonymous or default accounts, insecure remote access, unencrypted connections, outdated database software, unsafe plugins, and poor backup protection. A database account that can read or modify every schema creates a greater risk than an account restricted to the few tables needed by an application. A network-exposed database is not automatically vulnerable, but the exposure increases the number of systems that can attempt to connect.

An attacker who gains access to a database account may extract data, alter records, delete tables, or use the account's privileges to affect application integrity. A software vulnerability may create additional impact if the installed version and configuration are affected. The analyst should not assume these outcomes without evidence; account reviews, configuration inspection, patch checks, and controlled validation are required.

Defensive measures include binding MySQL to the required interface, restricting TCP/3306 with host firewalls and network security groups, and permitting connections only from approved application hosts and administrator jump servers. Use unique strong credentials, least-privilege grants, encrypted connections where traffic crosses networks, secure secret storage, and regular updates. Encrypt and test backups, log administrative activity, and alert on unusual queries or access patterns.

Confirm the database is not exposed beyond its intended network.

Review database accounts, grants, authentication plugins and remote-login permissions.

Separate application, database and administration network zones.

Test backup restoration and define a recovery procedure.

Possible attack paths and business impact :

The services can create a chain of risk when an attacker has a starting point inside the network. For example, a compromised workstation might discover the host, attempt to access SSH using stolen credentials, and then look for database connectivity from the compromised account. Alternatively, a vulnerable web application might expose data or application secrets that are later used to access MySQL. These are illustrative threat scenarios and must be validated against the real architecture.

The impact may include confidentiality loss, unauthorised changes, service interruption, regulatory or contractual consequences, incident-response costs, and reputational damage. The actual impact depends on the data stored, the host's role, available privileges, backup quality, and whether segmentation prevents lateral movement.

Risk assessment should consider both likelihood and impact. Internet exposure, weak authentication, known exploitable vulnerabilities, high privileges, and sensitive data can raise risk. Strong segmentation, timely patching, multi-factor authentication, monitoring, and tested recovery controls can reduce it. A simple risk matrix is a prioritisation aid, not a substitute for evidence-based scoring.

The report should avoid stating that the target is compromised merely because three ports are open. Instead, it should describe the exposure, the evidence collected, the validation needed, and the practical next steps. Findings should be ranked by risk and assigned to an accountable system owner with a target remediation date.

Threat scenario	Potential consequence	Validation focus
Unencrypted web traffic	Credential or session exposure	Confirm HTTP behaviour and where sensitive data is transmitted
SSH credential compromise	Unauthorised administrative access	Review authentication policy, logs and account privileges
Unrestricted database access	Data theft or modification	Test approved network reachability and inspect grants
Outdated service component	Potential exploitation of a known flaw	Verify exact package/build and vendor advisory applicability

Recommended network and host controls :

Network controls should enforce the principle of least exposure. A host firewall and network firewall should permit only the ports and source systems required for business operations. Where possible, place the database in a private server segment, use a controlled management network for SSH, and place web-facing components in an appropriate application or DMZ segment. Segmentation limits the consequences of a compromised device.

Host hardening should remove unused services, disable default accounts and sample applications, apply secure baseline configurations, and keep an accurate inventory of software and owners. Patch management should prioritise actively exploited and high-impact

vulnerabilities, while testing changes before production deployment. Configuration drift should be checked regularly.

Identity controls should include unique user identities, least-privilege access, multi-factor authentication for administrators, strong secret management, and prompt removal of departed or unnecessary accounts. For databases, applications should use dedicated service accounts with limited permissions instead of shared administrator credentials. Administrative activity should be attributable to an individual.

Encryption, backups and monitoring complete the defence. Use HTTPS for web interactions and TLS for database connections where appropriate. Protect backups from unauthorised alteration, store copies separately, and conduct restoration tests. Centralise relevant logs and alert on suspicious patterns. Incident-response plans should define isolation, evidence preservation, credential revocation, recovery, and communication responsibilities.

Apply deny-by-default firewall rules, then allow only documented business flows.

Use a patch and vulnerability-management process with owners and deadlines.

Maintain tested offline or immutable backups for critical data.

Review access and firewall rules at scheduled intervals and after system changes.

Verification and validation plan :

After initial discovery, the analyst should perform controlled validation under the written scope. The next step is not to exploit every open service, but to establish whether each service is required and whether a specific weakness exists. Validation may include checking the service package on the host, comparing it with official vendor advisories, reviewing configuration, and performing approved authenticated checks.

For HTTP, inspect redirect behaviour, TLS configuration, security headers, application access control and dependency versions. For SSH, verify the effective configuration, permitted authentication methods, account restrictions, key policy and login records. For MySQL, confirm the bind address, firewall path, account grants, TLS configuration, version and backup controls. Testing should avoid destructive actions and should use test accounts and data wherever possible.

Record each test's date, method, evidence, limitations and result. Use a finding template that includes title, affected asset, description, evidence, risk, business impact, likelihood, recommendation, owner and remediation target. A finding should be marked confirmed, suspected or informational to avoid overstating the evidence.

Retesting should confirm that the change actually reduced exposure. For example, after a firewall update, verify that only approved sources can reach the database; after patching, confirm the installed package and recheck the relevant advisory; after SSH hardening, test legitimate administrative access and review logs. Remediation must not break required business functions.

Obtain written permission and use the approved test window.

Use non-destructive checks and preserve logs and evidence.

Track each issue from discovery through remediation and retest.

Document residual risk where a service cannot be removed or fully restricted.

Prioritisation and sample finding register :

A useful assessment translates technical observations into a prioritised action plan. A port alone should not be assigned a critical rating. The analyst should use a recognised organisational risk method, such as likelihood multiplied by impact, and where appropriate refer to CVSS for a confirmed software vulnerability. CVSS describes technical severity; the organisation's business context determines final priority.

The following register is illustrative because the supplied scenario does not include exact service versions, firewall rules, authentication settings, or evidence of exploitation. The priorities should therefore be confirmed after validation. A service reachable only from a tightly controlled management segment may have lower risk than the same service reachable by every internal workstation.

Remediation owners should agree deadlines and document exceptions. For urgent exposure, temporary controls such as restricting source IPs can reduce risk while a patch or configuration change is prepared. The organisation should avoid leaving temporary controls in place indefinitely without review.

After remediation, a follow-up scan and configuration review should be compared with the original baseline. A successful outcome is not simply fewer open ports; it is that the host exposes only approved services, required services are securely configured, and monitoring and recovery controls are effective.

Illustrative finding	**Initial priority**	**Recommended action**
HTTP without confirmed HTTPS protection	Medium; validate context	Redirect to HTTPS, configure TLS and review sensitive traffic
SSH reachable beyond administrator network	High if confirmed	Restrict source networks, strengthen authentication and monitor
MySQL reachable from unapproved hosts	High if confirmed	Block unnecessary paths and allow only approved clients
Version possibly affected by advisory	Unconfirmed until verified	Confirm package/build and patch or apply vendor mitigation

Conclusion and references

The Nmap report identifies three services that require review: HTTP on port 80, SSH on port 22, and MySQL on port 3306. HTTP may expose data if sensitive traffic is not protected by

TLS and the application may have independent weaknesses. SSH is a high-value administration service that must be restricted and strongly authenticated. MySQL can expose sensitive data if network access, account privileges or software maintenance are weak.

The strongest response combines evidence-based validation with layered controls: remove unnecessary services, restrict network paths, patch supported software, use least privilege, protect credentials, encrypt traffic, monitor activity and maintain tested backups. Service and operating-system version detection helps guide the investigation but must be verified against vendor information and the actual host configuration.

The assessment should remain within written authorisation. Findings should be clearly distinguished from hypotheses, ranked by business risk, assigned to owners, and retested after remediation. These practices convert a scan from a list of ports into a practical security improvement plan.

Nmap Reference: https://nmap.org/book/man.html

CISA Known Exploited Vulnerabilities Catalog: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

OWASP Top 10: https://owasp.org/www-project-top-ten/

MySQL Reference Manual: https://dev.mysql.com/doc/

OpenSSH manual pages: https://www.openssh.com/manual.html

2 Purpose and interpretation of the GoPhish results

The scenario describes an authorised phishing-awareness campaign at ABC Technologies Pvt. Ltd. using GoPhish. The report states that 40% of employees clicked the phishing link, 20% entered login credentials, and several users downloaded a malicious attachment. These results indicate that the simulated message persuaded a substantial portion of the measured audience to take actions that could expose the organisation to social engineering.

Clicks, credential submissions and attachment downloads are different behavioural measures. A click shows interaction with the link, but does not by itself prove that malware ran or that an account was compromised. A credential submission indicates that the user entered information into the simulation page; in a well-designed exercise, the collected data should be limited to safe campaign metrics and should not capture real passwords. Attachment downloads demonstrate a risky action, but a download alone does not prove execution or infection.

The percentages should be interpreted using the number of delivered emails and the number of unique recipients. If 100 messages were delivered, 40 clicks and 20 credential submissions would represent the stated percentages only if the report defines the denominator that way. The report should clarify whether users who submitted credentials are included among clickers, whether events are unique, and whether email security tools or automated scanners affected tracking.

The campaign is most useful as a learning and risk-reduction activity, not as a way to blame employees. The purpose is to discover gaps in recognition, reporting, technical controls and response. Results should be communicated responsibly, with privacy safeguards and follow-up training.

Confirm the campaign was authorised by management and coordinated with IT/security.

Check delivery, click, submission and download denominators.

Do not equate a simulated action with confirmed compromise.

What the 40% click rate suggests :

A 40% click rate suggests that many recipients were willing to follow the link or found the message credible enough to interact with it. The cause cannot be inferred from the percentage alone. The message may have used urgency, authority, curiosity, a familiar brand, an unexpected document, or a topic related to an employee's work. The campaign design and employee feedback are needed to determine which cues influenced behaviour.

Employees may have clicked because the sender display name looked familiar, the URL was obscured, the email was expected, or the message arrived during a busy period. Some users may also have clicked accidentally or used the link to inspect the page without trusting it. Therefore, the result should be treated as a signal for further analysis rather than proof that all clickers lack awareness.

Clicking a link can expose a user to a fake sign-in page, a drive-by attempt, malicious redirects, or tracking. Modern browsers and endpoint protections reduce some risks, but they cannot compensate for every malicious page or credential-harvesting technique. A malicious link may also lead to a legitimate-looking cloud service where attackers attempt to collect information.

Training should teach employees to inspect the full sender address, verify unexpected requests through a second channel, hover over links where appropriate, use company-managed bookmarks for sign-in, and report suspicious emails rather than forwarding them widely. The organisation should make reporting easy through a visible mail-client button and provide prompt feedback after a report.

Teach employees to pause before urgent or unexpected requests.

Use a report-phishing button and explain what happens after reporting.

Use safe, organisation-approved simulations and avoid collecting actual credentials.

Measure repeat behaviour over time, not just one campaign.

Credential submission: risk and response :

The 20% credential-submission result is particularly important because credentials can provide direct access to email, collaboration systems, remote access services, cloud platforms or business applications. If an attacker obtains a password that is reused across systems, the damage can extend beyond the original service. Password-only authentication is also vulnerable to phishing even when the password itself is strong.

A credential-harvesting page may imitate a corporate login portal and relay information to an attacker. More advanced phishing can attempt to steal session tokens or persuade a user to

approve a fraudulent authentication request. Multi-factor authentication reduces many password-only attacks, but some methods are more resistant to phishing than others. Phishing-resistant authentication, such as FIDO2/WebAuthn security keys or passkeys deployed through an approved identity provider, offers stronger protection.

During a simulation, the organisation should not collect, store or expose actual passwords. The campaign can record a submission event without retaining the text entered. If an actual credential is believed to have been exposed outside a simulation, incident response should begin promptly: revoke sessions, reset affected credentials through the official identity platform, check sign-in logs, assess multi-factor authentication events and inspect for suspicious mailbox rules or OAuth grants.

Employees should know that reporting a mistake quickly is the right action. Punitive responses may discourage reporting and delay containment. Policies should encourage immediate, honest reporting and define a clear response process. Password managers, unique passwords, conditional access and least-privilege permissions can reduce the impact of stolen credentials.

Deploy phishing-resistant MFA for privileged and high-risk accounts where feasible.

Use unique passwords and an approved password manager.

Revoke sessions and investigate sign-ins when real credentials may be exposed.

Never store real passwords as part of a training campaign.

Attachment downloads and malware risk :

The report says several employees downloaded a malicious attachment. This suggests that attachment handling and file-verification habits need attention. The actual risk depends on file type, content, operating-system protections, macro settings, application patch levels and whether the file was opened or executed. A download does not establish that the endpoint was infected, so the organisation must verify the endpoint telemetry and campaign records.

Malicious attachments may use executable files, script files, shortcut files, archive files, weaponised documents or links embedded in documents. They may try to exploit an application vulnerability, persuade a user to enable active content, or lead to credential theft. Modern email gateways and endpoint detection tools can block many threats, but file types and delivery methods change frequently.

Employees should avoid enabling macros or active content in unexpected documents, should not bypass security warnings, and should verify unusual invoices, delivery notices or shared files through a known contact method. If an unexpected attachment is downloaded, the employee should report it and follow the organisation's incident-response instructions rather than opening it to investigate.

Technical controls include attachment sandboxing, anti-malware scanning, blocking high-risk file types where business needs permit, disabling macros from the internet, applying application updates, and using endpoint detection and response (EDR). Email authentication and domain reputation controls can help reduce spoofed or suspicious messages. Controls must be tuned to avoid unnecessary disruption to legitimate work.

Determine whether files were merely downloaded, opened or executed.

Use sandboxing and EDR to investigate suspicious files.

Disable risky active content by default and patch document viewers.

Provide a simple method for users to report unexpected attachments.

Human and organisational weaknesses :

The combined metrics show a need to strengthen several layers rather than attributing the result to a single human weakness. The click rate may indicate difficulty identifying suspicious messages; credential submission highlights the need for safer sign-in practices and identity controls; attachment downloads indicate a need for safer file handling and technical filtering. Each behaviour can be influenced by the design of the campaign and the working context.

Possible organisational contributors include high email volume, rushed workflows, unclear reporting routes, insufficiently visible security guidance, inconsistent onboarding, limited feedback after reports, and a culture in which employees fear punishment for mistakes. If legitimate internal messages frequently use urgent language or unexpected links, employees may learn habits that attackers exploit. Security awareness must therefore be supported by secure organisational practices.

Training should be role-based. Finance staff may need additional practice with invoice fraud and payment-change requests; HR may face fake CVs or employee documents; IT administrators may receive credential and remote-access lures; executives may be targeted through impersonation. Training examples should be realistic but safe, accessible, inclusive and relevant to the organisation's actual work.

Management should review whether employees can report a suspicious message in one step, whether the security team responds promptly, and whether business processes require independent verification for sensitive actions. A healthy security culture rewards early reporting, investigates system-level causes and uses campaign data to improve controls.

Create a non-punitive reporting culture.

Include phishing guidance in onboarding and periodic refreshers.

Tailor scenarios to job roles and common business workflows.

Require independent verification for payment, payroll or account-change requests.

User awareness programme :

A structured awareness programme should combine short training, practical demonstrations, recurring reminders and feedback. A one-time presentation is unlikely to build durable habits. Employees should learn common warning signs: mismatched sender addresses, unexpected attachments, unusual requests for credentials, pressure to act quickly, unfamiliar URLs, spelling or branding inconsistencies, and requests to bypass normal processes. However, polished grammar and familiar branding do not guarantee that a message is legitimate.

Training should teach a repeatable decision process: pause, inspect the sender and destination, question unexpected urgency, verify through a known independent channel, and report the message. Users should be shown how to use the organisation's reporting tool and what information to include. They should also understand that reporting a suspected phishing email is useful even if they are uncertain.

Use short modules during onboarding, quarterly refreshers, targeted training after a simulation, and special sessions for high-risk roles. Training should include mobile-device examples because URLs and sender details may be harder to inspect on small screens. Provide accessible formats and multiple languages where needed.

Evaluate learning with more than click rates. Useful measures include reporting rate, time to report, credential-submission rate, attachment-open rate where safely measured, repeat patterns, training completion and employee confidence. Share aggregate results with management and protect individual data. Campaign outcomes should be compared across similar campaigns and reviewed for changes in message difficulty.

Run short, regular, role-specific training rather than a single annual lecture.

Provide examples for desktop and mobile email clients.

Give immediate educational feedback after simulations.

Track reporting and response improvements as well as risky clicks.

Email security and identity controls :

Email security should use several complementary layers. Sender Policy Framework (SPF) identifies which systems are authorised to send for a domain; DomainKeys Identified Mail (DKIM) adds a cryptographic signature; and Domain-based Message Authentication, Reporting and Conformance (DMARC) tells receiving systems how to handle messages that fail alignment checks and provides reporting. These controls help reduce domain spoofing, but they do not prevent every phishing email, including messages from compromised legitimate accounts.

Secure email gateways can inspect reputation, URLs, attachments and impersonation patterns. Safe link inspection and time-of-click checks can reduce exposure to malicious destinations. Attachment detonation or sandboxing can identify suspicious behaviour. Controls should be monitored and tuned, since false positives can disrupt business operations and attackers continually adapt their techniques.

Identity security is equally important. Enforce multi-factor authentication, prioritise phishing-resistant methods for administrators and high-risk users, use conditional access based on device and sign-in risk, and disable legacy authentication where possible. Protect account recovery and help-desk workflows because attackers may target these processes instead of the login page. Limit application permissions and review third-party OAuth grants.

Use endpoint detection and response, application control, timely patching and least privilege to reduce the impact of a successful click. Backups, central logging and incident-response playbooks support recovery. No single control should be treated as a complete solution; the goal is to prevent, detect and contain attacks at multiple stages.

Configure SPF, DKIM and DMARC correctly and monitor reports.

Use URL and attachment protection in the email gateway.

Adopt MFA and stronger phishing-resistant authentication where feasible.

Review legacy authentication, mailbox rules, OAuth grants and sign-in alerts.

Organisational policies and reporting workflow :

ABC Technologies should maintain a clear acceptable-use and information-security policy covering suspicious email, credential handling, attachments, remote work, personal devices and reporting obligations. The policy should be easy to find, written in plain language and

supported by practical examples. Employees should know that they must never send passwords through email or enter them after following an unexpected link.

Sensitive business requests need verification rules. Payment-detail changes, payroll changes, gift-card purchases, password resets and requests for confidential files should be verified through a known independent channel. A reply to the suspicious email is not independent verification because the attacker may control the conversation. High-risk transactions should require separation of duties or a second approver.

A defined reporting workflow should allow an employee to report a message quickly. The security team should preserve the email headers and relevant evidence, determine whether other recipients received the message, block confirmed malicious indicators where appropriate, and check whether a user clicked, submitted information, downloaded a file or approved an authentication request. If compromise is suspected, isolate affected endpoints as appropriate and follow the incident plan.

Policies should specify responsibilities for IT, security, HR, legal, communications and business leaders. They should also cover privacy, retention, vendor management, and the safe design of simulations. Campaign data should be collected only for a defined security purpose and retained only as long as necessary.

Create a one-click report-phishing process.

Define escalation criteria and response-time expectations.

Require independent verification for sensitive transactions.

Review policy after incidents, simulations and major technology changes.

Incident response, metrics and improvement :

If a real phishing incident is suspected, the organisation should follow a documented process: report and triage, preserve evidence, contain the threat, eradicate malicious access, recover services, and learn from the incident. The exact actions depend on what occurred. A click alone may need investigation; credential submission may require session revocation and identity checks; an executed attachment may require endpoint isolation and forensic analysis.

Containment can include blocking a malicious sender or URL, removing messages from mailboxes, disabling or resetting affected accounts, revoking sessions and tokens, and isolating endpoints. The security team should search for related messages and signs of lateral

movement. It should preserve logs and timestamps, document actions and avoid destroying evidence unnecessarily. Notifications should follow legal and contractual requirements.

Metrics should be interpreted with context. Click rate measures one kind of interaction; credential-submission rate measures a more consequential simulated action; reporting rate measures protective behaviour; and time-to-report measures how quickly the organisation receives a warning. A lower click rate is useful, but a higher reporting rate and faster detection may be equally important.

Use a continual improvement cycle: plan a safe campaign, run it with approval, analyse aggregate results, provide tailored learning, improve technical controls, and repeat with comparable scenarios. Keep campaign difficulty consistent enough for trend comparison and document changes that could affect the numbers. Success means fewer risky actions, more early reporting, stronger controls and faster containment.

Follow the incident-response plan and preserve relevant evidence.

Revoke sessions and reset credentials when real exposure is plausible.

Use aggregate metrics and compare like-for-like campaigns.

Turn campaign findings into assigned actions with deadlines.

Conclusion and references :

The GoPhish report indicates that 40% of employees clicked the simulated phishing link, 20% entered credentials, and several downloaded a malicious attachment. These findings show opportunities to improve phishing recognition, credential protection, safe attachment handling and reporting. They do not, by themselves, prove that real accounts or endpoints were compromised.

The recommended approach combines user education with technical and organisational controls: regular role-based training, a non-punitive reporting culture, secure email authentication, URL and attachment filtering, endpoint protection, strong multi-factor authentication, least privilege, and independent verification for sensitive requests. A documented response process is essential to contain real incidents quickly.

ABC Technologies should repeat authorised campaigns, evaluate trends carefully, protect employee privacy and use findings to improve systems rather than shame individuals. The best outcome is a measurable increase in reporting and a reduction in successful risky actions, supported by technical controls that limit the damage when a person makes a mistake.

GoPhish documentation: https://docs.getgophish.com/

CISA phishing guidance: https://www.cisa.gov/secure-our-world/recognize-and-report-phishing

NIST Phishing guidance and cybersecurity resources: https://www.nist.gov/cybersecurity

OWASP Authentication Cheat Sheet:
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

DMARC overview: https://dmarc.org/

3 Purpose and meaning of DNS zone transfer

The scenario states that a DNS assessment using the dig utility found that the organisation's DNS server permits a successful DNS Zone Transfer, commonly called AXFR. A zone transfer is a DNS mechanism used to copy DNS records from a primary authoritative server to an authorised secondary server. It supports reliable DNS operations, but it should not normally be available to arbitrary clients.

The report says that internal hostnames, mail servers and DNS records were exposed. This means that an unauthorised requester may be able to obtain a structured view of the organisation's DNS namespace. The data can reveal naming conventions, server roles, mail infrastructure, subdomains and sometimes references to development or administrative systems. The exact information exposed depends on the contents of the zone.

AXFR success is a configuration weakness when the transfer is not limited to authorised secondary servers. It does not automatically mean that the DNS server has been taken over or that every listed host is reachable. DNS records are not passwords, and many public DNS records are intended to be visible. The security concern is the unnecessary aggregation of internal information and the reconnaissance advantage it may give an attacker.

The assessment should confirm which server answered, whether it is authoritative for the zone, which records were transferred, whether the zone is internal or public, and whether the request came from an authorised test system. Preserve the relevant output securely and avoid publishing sensitive internal names in a public report.

Verify the zone and server ownership before testing.

Determine whether the records are internal, public or split-horizon data.

Treat successful unauthorised AXFR as an information-disclosure finding.

How DNS and AXFR work :

DNS translates names such as service.example into resource records that help clients locate systems. Common record types include A and AAAA for IPv4 and IPv6 addresses, CNAME for aliases, MX for mail exchangers, NS for authoritative name servers, TXT for text information, and SOA for zone authority and serial information. DNS supports normal business functions, so security controls must preserve legitimate resolution.

A zone transfer allows one DNS server to replicate a zone from another. AXFR transfers the full zone; IXFR can transfer changes where supported and configured. Authoritative DNS

servers often use transfers between a primary and secondary server to maintain consistency and availability. The transfer should be explicitly configured rather than broadly allowed.

DNS uses different request types for ordinary lookups and zone transfers. A normal lookup returns records relevant to a queried name, while an unrestricted full transfer can reveal many records in one operation. This makes misconfigured AXFR useful for reconnaissance because it reduces the effort needed to discover names and relationships.

An administrator should maintain a clear list of authorised secondary servers and configure transfers only to those systems. Use network access controls and the DNS software's transfer restrictions, and consider transaction signatures (TSIG) for authenticating transfers between supported servers. TSIG complements rather than replaces network restrictions and careful key management.

Record type	**Purpose**	**Potential information revealed**
A / AAAA	Maps a name to an IP address	Host location and address ranges
MX	Identifies mail exchangers	Email provider or mail infrastructure
NS / SOA	Identifies authority and zone metadata	DNS topology and operational details
CNAME	Maps an alias to another name	Service relationships and naming conventions
TXT	Stores text data, often for verification or email policy	Configuration details; content should be reviewed

Security implications of exposed hostnames :

Hostnames can disclose an organisation's internal naming conventions and system roles. Names containing terms such as dev, test, vpn, admin, backup, staging or database may suggest where particular services are located. Naming information is not a vulnerability by itself, but it can help an attacker prioritise targets and form hypotheses about the organisation's architecture.

An attacker might combine DNS information with public certificate records, search engines, publicly available code, leaked configuration files or other authorisedly observable

information to build a broader picture of the organisation. This is a reconnaissance activity. The resulting list may help identify neglected systems, older application environments or remote-access infrastructure that deserve defensive review.

Internal hostnames should not be assumed secret in every case, and hiding names is not a substitute for authentication. The principal goal is to avoid exposing unnecessary internal records through public or untrusted DNS paths. Systems that are intentionally public must still be protected with access controls, patching and monitoring.

Defenders should classify zones, separate internal and external namespaces where appropriate, and avoid placing private-only records in public authoritative zones. Split-horizon DNS can provide different answers to internal and external clients, but it must be carefully configured to avoid leaking internal records. Remove stale records and document the business owner for each exposed name.

Inventory all records returned by the transfer.

Identify names that reveal internal roles or non-public environments.

Remove stale records and separate internal and external DNS data.

Do not rely on obscurity as the primary security control.

Potential attacker use and limitations :

An attacker may use exposed records to map the organisation's services, identify mail gateways, infer remote-access systems, and select targets for further probing. For example, a hostname that appears to identify a test environment may prompt defenders to verify that the system is patched and not connected to production data. The name alone does not prove that the system is vulnerable or accessible.

DNS data may also help an attacker prepare more convincing social-engineering messages by identifying business units, system names or service providers. Mail records can reveal which systems receive email, while aliases can expose relationships between services. This information may improve the credibility of phishing attempts, although DNS exposure is only one possible source of reconnaissance information.

The risk should not be exaggerated. A zone transfer does not grant login access, bypass firewalls, or prove that the listed hosts are running. Network reachability, authentication, service configuration and vulnerabilities must be assessed separately. Public DNS records are

designed to be queried; the weakness is an unintended full-zone disclosure, especially where the zone contains internal or operationally sensitive information.

The report should explain this distinction clearly: the finding is unauthorised disclosure of zone contents and the resulting reconnaissance advantage. The organisation should investigate whether the exposed records are truly internal, whether any names or addresses are sensitive, and whether the same information is exposed through other sources.

Map findings to specific records and their sensitivity.

Validate whether exposed hosts are actually reachable only within approved scope.

Assess social-engineering and infrastructure risks without assuming compromise.

Avoid destructive or intrusive follow-up testing without separate authorisation.

Risk assessment and business impact :

The severity of an unrestricted AXFR finding depends on the sensitivity and breadth of the zone, whether it is an internal zone, the network location of the DNS server, and what an attacker could do with the information. A public zone containing ordinary public records may present limited incremental risk. A private zone containing sensitive names and internal addresses can create a more meaningful reconnaissance risk.

Potential consequences include more efficient targeting, discovery of forgotten systems, improved phishing pretexts, and reduced effort for later attacks. Business impact may include increased likelihood of targeted intrusion, exposure of architectural details, and additional incident-response work. These are indirect consequences; the transfer itself is an information disclosure, not proof of a breach.

Risk assessment should document the threat actor, exposure path, data sensitivity, likelihood of misuse and impact on confidentiality, integrity and availability. The organisation should also consider whether internal DNS is reachable from guest networks, user workstations or external networks. Reachability from a broad network increases the potential audience able to request a transfer.

Use a consistent risk matrix and explain the basis for the rating. Do not assign a critical severity solely because AXFR succeeded. If the response contains internal system names, privileged infrastructure details or sensitive topology, the priority may be higher. Remediation should focus first on restricting transfers and then on reviewing exposed records and downstream access controls.

Factor	Lower-risk condition	Higher-risk condition
Zone contents	Only intended public records	Internal names, private addresses or sensitive topology
Who can request AXFR	Only named secondary servers	Any network client or untrusted source
Network exposure	Management network with strict ACLs	Public or broad user-network access
Record quality	Current and owner-reviewed	Stale, undocumented or revealing records

Secure configuration and access restrictions :

The primary corrective action is to restrict zone transfers to authorised secondary DNS servers. Administrators should use the DNS server's access-control settings to specify the permitted transfer peers and deny transfers to all other clients. Network firewalls should reinforce this policy by limiting DNS transfer traffic to known addresses where practical.

Where supported, use TSIG or an equivalent authenticated mechanism for server-to-server transfers. Keys must be generated securely, stored with restrictive permissions, rotated under a documented process and removed when no longer needed. TSIG does not replace access control; both should be used together where appropriate. Configuration syntax varies between DNS products, so changes must follow the official documentation for the deployed server.

Use separate authoritative servers or views for internal and external DNS where appropriate. Restrict management interfaces and zone administration to authorised administrators, use strong authentication, and log configuration changes. DNS software should be patched and run with least privilege. The server should expose only required services and should be monitored for unusual transfer requests.

Configuration changes should be tested in a staging or controlled maintenance window. A secondary server must still be able to transfer the zone after restrictions are applied. Overly broad blocking can interrupt legitimate DNS replication and affect availability, so identify all legitimate peers before making changes.

Allow AXFR only to explicitly authorised secondary servers.

Use TSIG where supported and manage keys securely.

Apply network ACLs in addition to DNS application controls.

Test replication after every policy change.

DNS architecture, record hygiene and privacy :

Secure DNS architecture begins with clear separation between public and internal records. Public authoritative zones should contain only records intended for public resolution. Internal hostnames, private addresses and operational details should be kept in appropriately protected internal zones. Split-horizon DNS may be suitable where internal and external clients need different answers, but access boundaries and forwarding paths must be documented.

Record hygiene reduces both confusion and unnecessary disclosure. Remove stale A, AAAA, CNAME and other records when services are retired. Review TXT records for accidental secrets or internal details; secrets should never be placed in DNS records. Ensure MX, NS and SOA records reflect the intended architecture and that domain ownership is documented.

DNSSEC can provide origin authentication and integrity for signed DNS data, helping resolvers detect certain forms of tampering. It does not prevent zone transfers or make internal records confidential. Similarly, encrypted DNS transports protect some client-to-resolver communications but do not replace authoritative-server access controls. Each control addresses a different security objective.

Maintain a DNS asset inventory with zone owners, purpose, classification, authorised secondary servers, registrar details and renewal responsibilities. Use change control for record additions and removals. Regular reviews can identify abandoned subdomains, unexpected records and configuration drift. DNS security should be part of the wider vulnerability and asset-management programme.

Separate internal and public zones where the architecture requires it.

Remove stale records and review TXT records for accidental disclosure.

Use DNSSEC for integrity where suitable, while recognising its limits.

Maintain ownership, change control and periodic record reviews.

Detection, monitoring and incident handling :

DNS logging can help identify attempted zone transfers and other unusual queries. Administrators should record transfer requests, source addresses, response outcomes and configuration changes where the server supports this. Repeated AXFR requests from unknown

systems, unexpected transfer volumes, or changes to authorised secondary-server lists should trigger investigation.

Monitoring should be proportionate to the environment and should avoid collecting more data than needed. Centralise relevant logs, protect them from tampering and define a retention period. Correlate DNS events with firewall logs, identity events and endpoint telemetry where this helps determine whether the request is part of broader reconnaissance.

If an unauthorised transfer is discovered, restrict the transfer path, preserve evidence, identify the affected zone and determine exactly what records were disclosed. Review whether those records contain internal addresses or sensitive topology, and check whether the same names are exposed through other sources. Update risk assessments and notify the appropriate system owners.

Incident response should distinguish exposure from exploitation. Unless there is separate evidence, do not state that a successful transfer means a system was compromised. If additional indicators suggest targeted activity, follow the organisation's incident-response plan and assess related services within the approved scope.

Alert on AXFR attempts from unauthorised sources.

Preserve logs and the exact set of exposed records.

Review firewall and DNS configuration changes.

Escalate if correlated evidence suggests broader reconnaissance or intrusion.

Verification and remediation checklist :

After correcting the configuration, the analyst should repeat the approved test from both an authorised secondary server and an unauthorised test source. The expected result is that the secondary server can complete a legitimate transfer, while an unauthorised source is denied. Testing should be coordinated with the DNS owner to avoid interrupting production replication.

Review the actual zone contents and classify records as public, internal or sensitive. Remove obsolete entries and move internal-only data to the appropriate protected zone. Confirm that external and internal clients receive the intended answers. Check that all legitimate secondary servers are documented and that no unknown server remains authorised.

Validate the server software version and security updates, review the transfer ACLs, confirm TSIG configuration where used, and ensure that logs capture relevant events. Document the

test source, timestamp, query type, response and any limitations. Keep the evidence in the approved report repository rather than publishing raw internal records.

Assign an owner and due date to each corrective action. Retest after changes, record residual risk and schedule periodic reviews. The finding can be closed when unauthorised transfers are denied, legitimate replication remains functional, exposed records have been reviewed, and monitoring is in place.

Test allowed transfer from a named secondary server.

Test denial from an unauthorised source within the approved scope.

Review and classify all exposed records.

Document evidence, owner, due date and retest result.

Conclusion and references :

The successful AXFR result indicates that the DNS server permits a full zone transfer to a requester that should not be authorised, according to the scenario. The exposed hostnames, mail servers and records can give an attacker a useful reconnaissance map and may help support targeted phishing or infrastructure probing. However, the finding does not by itself prove that any host was compromised or that every record is confidential.

The main remediation is to restrict transfers to explicitly authorised secondary servers, reinforce the restriction with network ACLs, and use TSIG or an equivalent supported mechanism where appropriate. The organisation should also separate internal and public DNS data, remove stale records, patch DNS software, protect administration, monitor transfer attempts and retest the configuration.

DNS security is a combination of confidentiality-aware zone design, integrity, availability, access control and operational monitoring. A successful remediation preserves legitimate replication while preventing unauthorised disclosure. The organisation should keep a clear record of evidence and residual risk and review DNS configuration regularly.

ISC BIND 9 Administrator Reference Manual: https://bind9.readthedocs.io/

IETF RFC 5936 — DNS Zone Transfer Protocol (AXFR): https://www.rfc-editor.org/rfc/rfc5936

IETF RFC 8945 — Secret Key Transaction Authentication for DNS (TSIG): https://www.rfc-editor.org/rfc/rfc8945

IETF RFC 4033 — DNS Security Introduction and Requirements: https://www.rfc-editor.org/rfc/rfc4033

dig manual: https://bind9.readthedocs.io/en/latest/manpages.html